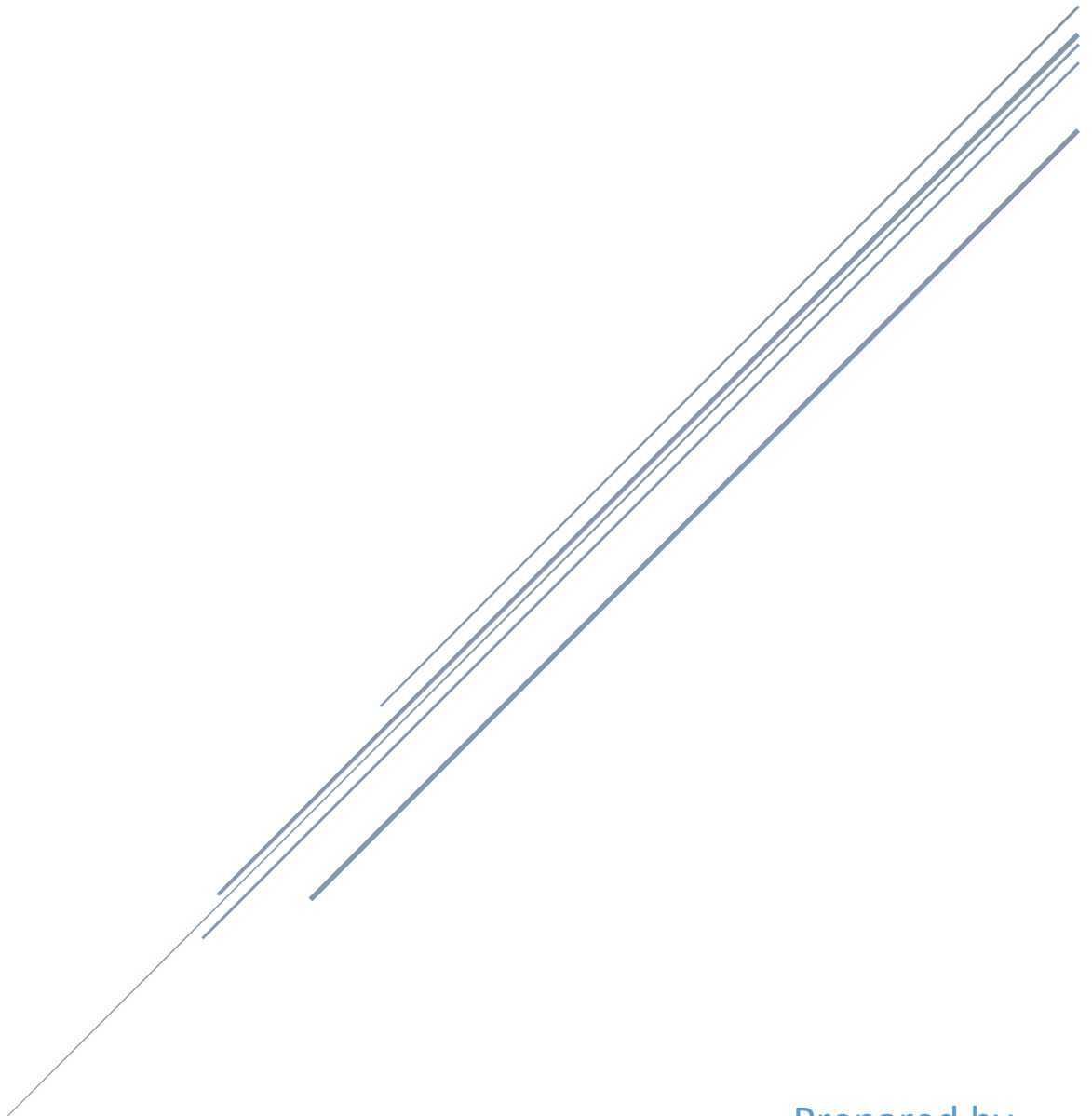


Phishing Email Detection & Awareness System



Prepared by
Abel Wondwossen

Table of Contents

Introduction	2
Example1:.....	3
Example 1 Email headers:	3
Example 2:.....	5
Example 2 Email headers:	5
Example 3:.....	7
Example 3 Header:	8
DO	10
Don'ts	10
Conclusion	11

Introduction

In modern business, email is essential. It is also the primary weapon of cybercriminals. Every day, organizations of all sizes face a relentless stream of malicious messages engineered to deceive, steal, and disrupt.

The era of crude, error-filled "Nigerian prince" scams is over. Today's phishing attacks are sophisticated, highly targeted operations. They are designed to bypass technical filters and exploit the one vulnerability common to every organization: **human judgment**.

A single click can trigger data theft, significant financial loss, and lasting reputational damage. Technology alone cannot stop these threats. The strongest defense is **informed awareness**.

This guide adopts a forensic approach to email security. We will not trust display names or logos at face value. Instead, we will systematically dissect every suspicious message, focusing on five critical areas:

Analyze Email Headers: Trace the email's true origin by examining its hidden metadata.

Inspect Sender Domain & Links: Scrutinize email addresses and URLs for subtle forgeries.

Identify Phishing Indicators: Recognize the linguistic and psychological tactics used to manipulate recipients.

Classify Email Risk: Categorize threats based on objective evidence, from low-risk spam to targeted attacks.

Create Prevention & Awareness Guidelines: Establish clear protocols to foster a culture of security.

Essential Tools for Analysis

Effective analysis requires the right instruments. The following tools will be referenced throughout this guide to assist in your investigations:

- **Email Header Analysis**
 - MXToolbox Email Header Analyzer
 - Google Admin Toolbox Messageheader
- **Link and Domain Inspection**
 - **Browser-Based Tools:** Utilize browser extensions or online scanners (e.g., VirusTotal) to safely inspect URLs and domains without direct interaction.

Example1:

From: " Abel Wondwossen, CEO" <abel.wondwossen @company.com >
To: accounts.payable@company.com
Subject: URGENT: Wire Transfer Required

I am in a client meeting and need an immediate wire transfer of \$24,850 to secure a new contract. I cannot access the banking portal right now. Please process payment to the account below and send confirmation to my personal email once completed.

Bank: Chase
Account Name: Synergy Consulting LLC
Account Number: 7843221190
Routing: 021000021

I will follow up with paperwork tomorrow.

Regards,
James

Example 1 Email headers:

Message ID: <16233445.789.1773817345678.JavaMail.MWWVACCAACC104\$@10.20.30.40>

Created at: Mon, Mar 16, 2026 at 9:47 AM (Delivered after 12 seconds)

From: "Abel Wondwossen, CEO" <abel.wondwossen@company.com>

To: accounts.payable@company.com

Subject: URGENT: Wire Transfer Required

SPF: FAIL with IP 185.142.53.102

DKIM: FAIL

DMARC: FAIL

Reply-To: abel.wondwossen.personal@gmail.com

Return-Path: <bounce@malicious-server.ru>

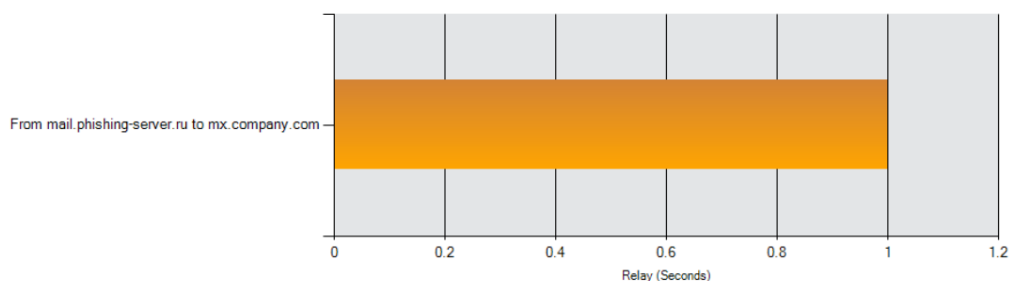
Authentication-Results: spf=fail (company.com: 185.142.53.102 is not permitted)

Received: from mail.phishing-server.ru (185.142.53.102) by mx.company.com

Key Phishing Indicators

1. Header Analysis Using MXToolbox

Received Delay: 0 seconds



Hop	DelayFrom	By	With Time (UTC)	Blacklist
1	*	mail.phishing-server.ru 185.142.53.102	mx.company.com	☐

Using the MXToolbox Email Header Analyzer reveals critical anomalies. The originating IP address (185.142.53.102) resolves to mail.phishing-server.ru—a domain with no legitimate connection to the claimed sender's organization. This alone constitutes a significant red flag.

2. Sender and Reply-to Address mismatch

The email claims to originate from abel.wondwossen@company.com, yet the Reply-To field directs responses to abel.wondwossen.personal@gmail.com. This discrepancy represents a classic phishing tactic: the attacker spoofs an internal address while ensuring replies bypass corporate security monitoring.

3. Authentication failures

The email fails all three major email authentication protocols:

- SPF (Sender Policy Framework): FAIL — The sending server (185.142.53.102) is not authorized to send emails on behalf of company.com.
- DKIM (DomainKeys Identified Mail): FAIL — The message lacks a valid cryptographic signature verifying its integrity.
- DMARC (Domain-based Message Authentication, Reporting & Conformance): FAIL — The message fails both SPF and DKIM checks, and no alignment exists with the sender's domain.

These authentication failures provide conclusive evidence that the email did not originate from legitimate company infrastructure.

Risk classification: High

Indicator	Finding	Risk Weight
SPF Result	FAIL	Critical
DKIM Result	FAIL	Critical
DMARC Result	FAIL	Critical
Reply-To Mismatch	Yes (external domain)	High
Originating IP	Associated with malicious server	Critical

Prevention & Response Guidelines

- Verify unexpected payment requests through alternate communication channels (phone call, in-person)
- Hover over links to reveal actual URLs before clicking
- Report suspicious messages to IT security immediately
- Never use Reply-To addresses that differ from the sender

Example 2:

From: "UPS Delivery" <notifications@ups.com>
To: customer@gmail.com
Subject: Your package could not be delivered

UPS Delivery Notification

Your package (#US-4491827-02) could not be delivered due to an incomplete address.

Please confirm your shipping information within 12 hours to avoid return to sender:

Update Address: [Click Here]

Tracking Number: 1Z9999X1234567890

Thank you,
UPS Customer Service

Example 2 Email headers:

Message ID: <5523891.234.1773891345678.JavaMail.UPSWEB\$@10.98.76.54>

Created at: Monday, March 22, 2026 at 9:45 AM (Delivered after 2 seconds)

From: "UPS Delivery" <notifications@ups.com>

To: customer@gmail.com

Subject: Your package could not be delivered

SPF: FAIL with IP 103.45.67.89 Learn more

DKIM: none

DMARC: FAIL Learn more

Reply-To: support@ups-delivery-service.com

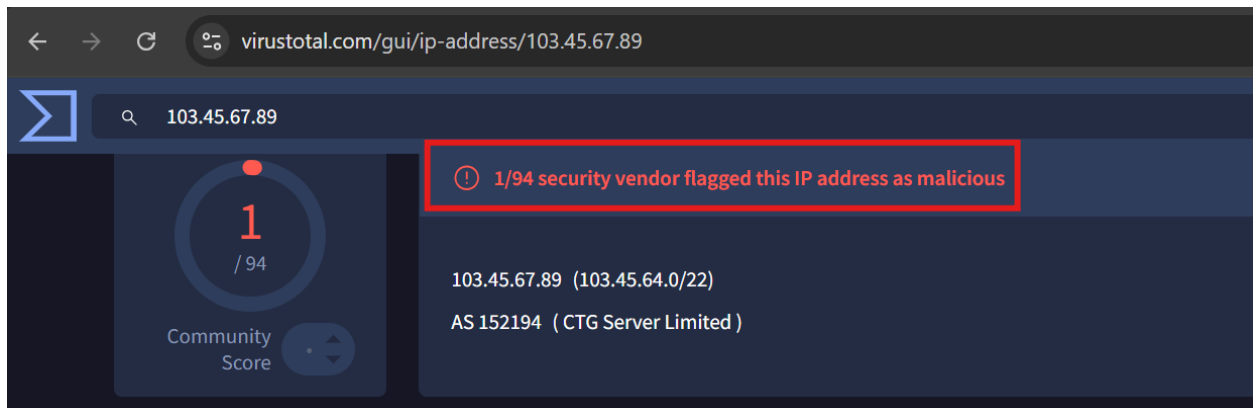
Return-Path: <bounce@ups-delivery-service.com>

Authentication-Results: spf=fail (ups.com: 103.45.67.89 is not permitted)

Received: from mail.fake-ups-server.com (103.45.67.89) by mx.gmail.com

Key Phishing Indicators

1. Link and domain inspection



Using VirusTotal to inspect the infrastructure associated with this email reveals critical red flags:

- The originating IP address (103.45.67.89) resolves to mail.fake-ups-server.com, a domain with no legitimate affiliation with UPS.
- VirusTotal analysis identifies this IP and associated domain as malicious, with prior detections for phishing and fraud campaigns.

The embedded link ([Click Here]) directs users to a fraudulent website designed to harvest personal information, payment details, or login credentials.

2. Sender and Reply-to Address mismatch

The email displays a trusted sender address—notifications@ups.com—but the Reply-To field is set to support@ups-delivery-service.com. This mismatch reveals the attacker's intent:

- The visible sender impersonates a legitimate UPS notification address.
- The Reply-To redirects responses to a domain controlled by the attacker (ups-delivery-service.com), ensuring any replies bypass legitimate UPS systems.

3. Authentication failures

The email fails critical authentication checks:

- SPF (Sender Policy Framework): FAIL — The sending server (185.142.53.102) is not authorized to send emails on behalf of ups.com.
- DKIM (DomainKeys Identified Mail): None— No cryptographic signature is present to verify the message's integrity.
- DMARC (Domain-based Message Authentication, Reporting & Conformance): FAIL — The message fails alignment checks and does not conform to UPS's DMARC policy.

These authentication failures provide conclusive evidence that the email did not originate from legitimate company infrastructure.

4. Psychological Manipulation Techniques

The attacker employs well-documented social engineering tactics to impair recipient judgment:

- **Urgency:** The 12-hour deadline creates artificial time pressure, discouraging careful scrutiny.
- **Fear of Loss:** The threat of the package being returned leverages anxiety about lost parcels.
- **Authority:** Impersonating a well-known logistics provider exploits trust in established brands.

These emotional triggers are designed to override rational decision-making and prompt immediate, unverified action.

Risk Classification: HIGH

Indicator	Finding	Risk Weight
SPF Result	FAIL	Critical
DKIM Result	none	High
DMARC Result	FAIL	Critical
Reply-To Mismatch	Yes (external domain)	High
Originating IP/Domain	Malicious per VirusTotal	Critical
Social Engineering	Urgency + fear tactics	High
Return-Path Domain	Unrelated to claimed sender	Medium

Prevention & Response Guidelines

- Never click links in unsolicited delivery notifications. Instead, navigate directly to the official carrier website and enter tracking information manually.
- Verify package status through official apps or previously verified communication channels.
- Examine sender email addresses carefully; legitimate UPS notifications do not originate from unrelated domains.

Example 3:

From: "Netflix" <account-security@netflix.com>

To: user@gmail.com

Subject: Your account has been suspended

Dear Valued Customer,

We have detected unusual activity on your account and have temporarily suspended your access to protect your information.

To restore your account, please verify your payment information within 24 hours:

[Verify Account Now](#)

If you do not complete this verification, your account will be permanently closed.

Thank you for being a Netflix member.

Netflix Account Team

Example 3 Header:

Message ID: <9981234.567.1773891789012.JavaMail.NFLXWEB\$@10.23.45.67>
Created at: Monday, March 22, 2026 at 2:30 PM (Delivered after 4 seconds)
From: "Netflix" <account-security@netflix.com>
To: user@gmail.com
Subject: Your account has been suspended
SPF: FAIL with IP 185.130.5.253 [Learn more](#)
DKIM: none
DMARC: FAIL [Learn more](#)
Reply-To: account-security@netflix-verify.com
Return-Path: <bounce@netflix-verify.com>
Authentication-Results: spf=fail (netflix.com: 185.130.5.253 is not permitted)
Received: from mail.phishing-server.com (185.130.5.253) by mx.gmail.com

Key Phishing Indicators

1. Generic Greeting

The email opens with "Dear Valued Customer" — a generic salutation that deviates from legitimate Netflix communication standards.

- Legitimate Netflix emails address recipients by their actual name or the profile name associated with the account.
- Phishing indicator: Generic greetings signal a mass-sent campaign where the attacker lacks specific recipient information.

This impersonal approach represents a deliberate attempt to maximize the target pool while revealing the fraudulent nature of the message to informed recipients.

2. Sender and Reply-To Address Mismatch

The email displays a trusted sender address—account-security@netflix.com—while the Reply-To field points to account-security@netflix-verify.com.

1. Authentication failures

The email fails critical authentication checks:

- SPF (Sender Policy Framework): FAIL —The sending server (185.130.5.253) is not authorized to send on behalf of netflix.com. Legitimate Netflix account emails originate from authorized, authenticated infrastructure.
- DKIM (DomainKeys Identified Mail): None— No cryptographic signature is present to verify the message's integrity or authenticity. Netflix signs its legitimate transactional emails.
- DMARC (Domain-based Message Authentication, Reporting & Conformance): FAIL —The message fails alignment checks. Netflix enforces strict DMARC policies; this message would be rejected or quarantined by properly configured email systems.

These authentication failures provide conclusive evidence that the email did not originate from legitimate company infrastructure.

2. Psychological Manipulation Techniques

"Temporarily suspended," "within 24 hours," "permanently closed" — all designed to create panic and bypass critical thinking.

Tactic	Language Used	Psychological Effect
Fear of Loss	"Your account has been suspended"	Creates immediate anxiety about losing access to a valued service
Urgency	"within 24 hours"	Imposes artificial time pressure, discouraging careful scrutiny
Permanent Consequence	"permanently closed"	Amplifies fear by threatening irreversible action
Authority	"Netflix Account Team"	Exploits trust in established corporate entities
False Reassurance	"to protect your information"	Frames the fraudulent action as a security measure

3. Risk Classification: **HIGH**

Indicator	Finding	Risk Weight
SPF Result	FAIL	Critical
DKIM Result	none	Critical
DMARC Result	FAIL	Critical
Reply-To Mismatch	Yes (netflix-verify.com)	High
Originating IP/Domain	Malicious (phishing-server.com)	Critical
Generic Greeting	"Dear Valued Customer"	Medium
Social Engineering	Urgency + fear of permanent closure	High

4. Prevention & Response Guidelines

- Never click links in unsolicited account-related emails. Navigate directly to the official website (e.g., netflix.com) by typing the address into your browser.
- Verify account status by logging into your account directly rather than through email links.
- Examine sender addresses carefully. Legitimate Netflix emails come from @netflix.com domains only, not variations like netflix-verify.com.
- Be suspicious of generic greetings. Legitimate service providers typically address you by name.
- Question urgency tactics. Reputable companies do not demand immediate action under threat of permanent account closure

DO

Do	Why
Pause and scrutinize before clicking or responding.	Phishing relies on impulsive reactions. A brief pause can break the attacker's psychological manipulation.
Verify the sender's email address by examining the full address, not just the display name.	Attackers spoof display names (e.g., "CEO Name") while using fraudulent domains.
Check for authentication failures using email header analysis tools (e.g., MXToolbox, Google Admin Toolbox).	SPF, DKIM, and DMARC failures provide technical proof that the email is not legitimate.
Compare the From address and Reply-To address.	If they differ—especially if one uses an external domain—the email is highly suspicious.
Hover over links before clicking to reveal the actual destination URL.	Attackers disguise malicious links behind legitimate-looking anchor text.
Navigate directly to official websites by typing the URL into your browser.	This ensures you are interacting with the legitimate service, not a fraudulent copycat site.
Verify unusual requests through alternate channels.	If an email requests a wire transfer, password reset, or sensitive data, confirm via phone call or in-person conversation.
Report suspicious emails to your IT or security team immediately.	Early reporting enables rapid response and protects others in the organization.

Don'ts

Don't	Why
Don't trust the display name alone.	Display names are easily forged. Always verify the actual email address.
Don't click links in unsolicited or unexpected emails	Links often lead to credential-harvesting sites or malware downloads.
Don't respond to emails in response to unsolicited or unexpected requests	Responses go directly to attackers, bypassing legitimate systems.
Don't comply with urgent requests that require immediate action without independent verification	Urgency is the attacker's primary tool to override critical thinking.
Don't open unexpected attachments.	Attachments may contain ransomware, malware, or other malicious payloads.
Don't provide personal information, credentials, or payment details in response to unsolicited emails or through email links or forms	Legitimate organizations do not request sensitive information through unsolicited emails.
Don't ignore authentication failures.	SPF, DKIM, and DMARC failures are definitive technical evidence of forgery.
Don't assume an email is safe because it appears to come from a known brand	Brand impersonation is one of the most common phishing techniques.

Conclusion

In conclusion, while phishing remains a pervasive threat, its risks can be effectively mitigated. By strictly adhering to the **security protocols** and **best practices** outlined above, we can maintain a robust defense and ensure the ongoing protection of our information assets.